

Tema 3 — Anexo A: Agent Identity, SPIFFE en producción

Slides independientes del deck principal de Tema 3 — después del Anexo 0 y de 3.3/3.4 (SPIFFE/SPIRE, SVID)

Agent Identity: cómo GCP implementa SPIFFE en producción

- Implementación real del estándar SPIFFE — mismas piezas formales de la teoría: **Trust Domain**, **Workload Identifier**, **SVID**
- No una reinterpretación libre ni un rebrand: aplicadas a la infraestructura serverless de Vertex AI (Anexo 0)
- Producto: **Agent Identity**, dentro de Gemini Enterprise Agent Platform

Recordatorio: dónde vive el agente

- Agent Engine/Agent Runtime: capa serverless que aloja el objeto del agente ya serializado (ver Anexo 0)
- Sabe conectar los *services* pluggables del framework a backends gestionados de Google
- Agent Identity es el mismo patrón, aplicado a identidad criptográfica en vez de sesión/memoria

De SPIRE a Agent Identity: mismo bootstrapping

- Teoría: identidad emitida dinámicamente tras *attestation* — en clase, SPIRE consultando al kubelet
- En GCP: la plataforma de confianza es el propio Google Cloud → **Agent Identity**
- Al desplegar, GCP asigna SPIFFE ID + certificado X.509 automáticamente — parte del mismo momento de `deploy` que serializa el agente (Anexo 0)

Formato real del SPIFFE ID en GCP

```
spiffe://agents.global.<ORGANIZATION_ID>.system.id.goog/  
resources/aipatform/projects/<PROJECT_NUM>/  
locations/<LOCATION>/reasoningEngines/<AGENT_ID>
```

- Misma estructura formal `trust-domain` + `workload-identifier` de la especificación SPIFFE
- Trust domain gestionado por Google; workload identifier codifica la jerarquía completa de recursos GCP

Attestation en dos niveles

Nivel de plataforma

- Serverless: no hay daemon local de SPIRE — ese paso no existe
- Mecanismo *agentless*: infraestructura de Google da fe del nodo desde afuera (análogo al rol del kubelet)

Nivel de workload

- Valida URI exacto del recurso, contexto IAM autorizado, y (BYOC/ADK) que el código corresponda a lo desplegado

Honestidad metodológica sobre la attestation

- Nombres específicos de evidencia ("metadata server attestation", "binary spec hash") — **no vienen de documentación oficial de Google**
- Vienen de análisis externos (blogs de seguridad) interpretando la caja negra desde afuera
- Confirmado en fuente oficial: el **resultado** — SPIFFE ID + X.509-SVID de 24h, renovado automáticamente
- En clase: distinguir "mecanismo probable según terceros" de "resultado confirmado por Google"

El SVID de 24 horas

- X.509-SVID: certificado X.509 estándar que embebe el SPIFFE ID como URI en la extensión **Subject Alternative Name (SAN)** — mismo mecanismo de la especificación SPIFFE, no una variante propietaria
- Validez máxima: 24 horas, rotación automática sin intervención del desarrollador
- Mismo principio de SVIDs de corta vida de SPIRE (ahí: minutos/horas) — acá el ciclo por defecto es de un día

Doble binding: mTLS y DPoP, en dos tramos distintos

- **No** es mTLS + DPoP simultáneo sobre la misma conexión
- Agente → APIs de GCP directamente: **mTLS** con el certificado X.509
- Agente → Agent Gateway → herramientas/MCP: el gateway **termina el mTLS** ahí
- De ahí en adelante: **DPoP** (RFC 9449, IETF)

Cómo funciona DPoP, técnicamente

- Cliente genera, por request, un JWT firmado con su clave privada: el **DPoP proof**
- Claims: `htm/htu` (método y URL de destino), `ath` (hash del token de acceso)
- Servidor verifica que el proof fue firmado por la clave asociada al token → token atado a la posesión de esa clave, sin depender de sesión TLS continua
- Token robado sin la clave privada = inservible fuera del proceso que la controla

Delegación de identidad: agente solo vs. en nombre de un usuario

- Autoridad propia: SPIFFE ID del agente (leer su base vectorial, logs de auditoría)
- Autoridad delegada: el **auth manager** combina identidad atestada del agente + token del usuario final → token scoped de corta duración para esa herramienta/acción
- Patrón de "principal compuesto" (agente + usuario) — documentado en varios frameworks de identidad agéntica, no exclusivo de Google

Qué es automático y qué configurás vos

Automático (Google)	Configurás vos
SPIFFE ID + certificado X.509 al deploy	Habilitar Agent Identity en Agent Engine
Attestation de dos niveles	Otorgar permisos IAM al SPIFFE ID (modelo IAM de Service Account)
Renovación del SVID cada 24h	Auth providers en el auth manager
Binding criptográfico mTLS/DPoP	Context-Aware Access / VPC-SC adicionales

Nota de madurez, para no prometer de más

- No hay aviso explícito de Preview/GA para el **conjunto** de Agent Identity + Agent Gateway en doc oficial (a diferencia de Service Extensions — ver Anexo B)
- Gemini Enterprise Agent Platform: anunciada recién en abril 2026 → re-chequear antes de prometer producción
- **Sí confirmado como GA:** despliegue básico en Agent Runtime, y Model Armor sobre Agent Gateway

Transición al Anexo B

- Autenticación resuelta: mismo estándar SPIFFE de la teoría — Trust Domain, Workload Identifier, SVID con SAN — sin secretos estáticos
- Mismo patrón de servicios enchufables → backends gestionados que vimos en Anexo 0 (Sessions/Memory), acá aplicado a identidad
- Falta la otra mitad: **PEP** y **PDP** — quién decide qué puede hacer el agente → Anexo B

Fuentes

- [Agent Identity overview | IAM | Google Cloud Documentation](#)
- [Use agent identity with Vertex AI Agent Engine | Google Cloud](#)
- [Authenticate using an agent's own authority | Google Cloud Documentation](#)
- [Agent Gateway overview | Gemini Enterprise Agent Platform | Google Cloud Documentation](#)
- RFC 9449 — OAuth 2.0 Demonstrating Proof of Possession (DPoP), IETF